

BUSINESS REQUIREMENTS DOCUMENT

MyHealthQR

Secure QR-Based Patient Health Record Access Platform

Document Version	1.0
Prepared By	Namrata Modha
Role	Technical Lead & BSA Contributor
Project Team	Group 1, Fanshawe College BISA
Date	April 2025
Status	Final
Outcome	1st Place, Fanshawe Capstone Showcase 2025

Document Change Log

Version	Date	Author	Description
1.0	April 17, 2025	Namrata Modha	Initial BRD, Final version post-capstone delivery

1. Executive Summary

MyHealthQR is a secure, PIPEDA-compliant web application designed to address a critical gap in emergency healthcare delivery: first responders and healthcare providers have no reliable, instant way to access a patient's medical information at the point of care.

The system provides each patient with a unique QR code linked to their self-managed health profile. Scanning the code gives any authorized third party read-only access to patient-approved critical information: allergies, chronic conditions, medications, and emergency contacts, without requiring a login or healthcare system integration.

The project was executed by a six-member cross-functional team across four milestones from January to April 2025 using Agile principles, weekly standups, and milestone-based delivery. The application was built on a Laravel/PostgreSQL stack and delivered on schedule. It won first place at the Fanshawe College Business and Information Systems Architecture (BISA) Capstone Showcase, April 2025.

2. Business Problem

Managing patient care in emergency or unplanned situations is severely constrained by the unavailability of immediate medical information. First responders, paramedics, school staff, and temporary caregivers have no standardized method to retrieve allergy data, chronic conditions, or emergency contacts without either contacting the patient directly or accessing proprietary healthcare systems that require credentials they do not hold.

Existing solutions either require healthcare system integration (inaccessible to first responders), rely on physical cards that are easily lost or outdated, or place the burden on the patient to communicate critical information verbally, which is impossible during a medical emergency.

Core Problem Statement: How can a patient's critical medical information be made instantly accessible to any authorized third party, without compromising privacy, without requiring a healthcare system account, and in full compliance with Canadian privacy law (PIPEDA)?

3. Business Objectives

- Enable any authenticated user to create and maintain a digital health profile accessible via QR code.
- Allow third-party users (first responders, caregivers, teachers) to retrieve patient-authorized health data in under 30 seconds using any mobile device.
- Give patients granular control over which fields are visible to third-party scanners, respecting individual privacy preferences.
- Ensure full compliance with PIPEDA through consent capture at registration, audit logging, and encrypted data storage.
- Deliver a system usable with no more than 30 minutes of orientation for any user type.

4. Project Scope

4.1 In Scope

- User registration with email verification, PIPEDA consent capture, and guardian consent for users under 18
- Patient profile management: personal information, emergency contacts, and medical data (allergies, conditions, medications)
- Privacy toggle controls allowing users to show or hide specific profile fields during QR scan
- Unique QR code generation per user profile, auto-triggered after successful email verification
- Quick Help feature: user-defined emergency care instructions surfaced to third-party scanners
- Role-based access control: User, Third-Party Scanner, and System Administrator
- Audit logging for QR code scans, email verifications, and QR code generation events
- Pre-seeded System Administrator role with ability to view and delete user data (v1: database-level access; admin UI dashboard deferred to future enhancement)
- Fully responsive interface optimized for desktop, tablet, and mobile devices

4.2 Out of Scope

- Integration with external healthcare systems (OHIP, hospital EHRs, pharmacy systems)
- Development or support of hardware QR scanners
- Native mobile application (web-responsive only)
- Clinician-level data entry or validated medical records
- Cloud deployment and hosting (deferred to future enhancement)
- Advanced features: multi-factor authentication (MFA), AI-driven analytics

5. Stakeholder Analysis

Stakeholder	Type	Interest	Influence	Role in Project
Patients / Primary Users	Internal	High	High	Create and manage health profiles; control data visibility via privacy toggles
Third-Party Users (First Responders, EMTs, Caregivers, Teachers)	External	High	Medium	Scan QR codes and consume emergency health data in read-only format
System Administrator	Internal	Medium	High	Pre-seeded role (defined in database); responsible for user account management and PIPEDA-compliant data deletion. In v1, administrative actions are performed at the database level.
Guardians / Parents	External	High	Medium	Provide consent for minor users; create and manage profiles on behalf of minors
Project Supervisors (Prof. Moraes, Prof. Abou Taka)	Internal	Medium	High	Academic oversight; requirements validation; formal project sign-off authority
Development Team (6 members)	Internal	High	High	Cross-functional delivery: Project Manager, Technical Lead, Scrum Master/Developer, Solution Architect, Business Analyst/Product Owner, Quality Assurance

6. Business Requirements

6.1 Functional Requirements

FR-01 User Registration and Authentication

The system must allow new users to register using a unique email and a password meeting defined security requirements (minimum 8 characters; uppercase, lowercase, numeric, and special character). Email verification must be completed before account activation. For users under 18, a guardian consent field must be displayed at registration. Three consent fields must be captured and stored at the user model level: `pipeda_consent`, `privacy_settings`, and `security_agreement_signed`.

FR-02 Patient Profile Management

Authenticated users must be able to create, view, update, and delete their patient profiles. Profile data includes: first name, last name, date of birth, contact information, emergency contact name and phone, and profile picture. Users must be able to control the visibility of individual fields to third-party scanners via real-time privacy toggles. Toggle states are persisted in the database as JSON and enforced at QR scan time.

FR-03 Medical Information Management

Authenticated users must be able to add and update self-reported medical data including allergies, chronic conditions, and current medications. All entries are stored as structured JSON. A disclaimer must be displayed on save, confirming that the user accepts sole responsibility for data accuracy. Medical data must be scoped to the individual user and inaccessible to other users or unauthenticated parties.

FR-04 QR Code Generation and Management

The system must automatically generate a unique QR code for each user profile upon successful email verification. The QR code encodes a randomly generated unique identifier linked to the user profile, not raw personal data. Users must be able to view, download, and print their QR code from their profile dashboard. QR codes remain persistent unless the user account is deleted.

FR-05 QR Code Scanning and Third-Party Access

Any individual with a mobile device and internet access must be able to scan a user's QR code and retrieve only the information the user has approved for external visibility. Scanned data is displayed in read-only format. Third-party users do not require a registered account. Each scan event must be logged with a timestamp for audit compliance.

FR-06 Quick Help Feature

Users must be able to enter emergency care instructions that appear as a priority panel when their QR code is scanned. Quick Help content is controlled by user-configured toggles and is surfaced to third-party scanners based on the user's visibility preferences.

FR-07 System Administrator Access

The system defines a pre-seeded administrator role enforced via Laravel RBAC middleware. The admin role is distinguished from standard user roles at the database level (role field in the users table). In v1, administrative operations including viewing registered users and deleting accounts, are executed directly at the database level. A dedicated admin UI dashboard with full user management capabilities is identified as a future enhancement.

FR-08 Audit Logging

The system must maintain a timestamped log of key events: QR code scans, QR code generation, and email verifications. Logs must be accessible for compliance review to support PIPEDA accountability obligations.

6.2 Non-Functional Requirements

ID	Category	Requirement
NFR-01	Security	All passwords hashed using Laravel's built-in bcrypt. CSRF protection and XSS prevention enforced across all forms. RBAC restricts data access by role. Sensitive fields must not be exposed in URL parameters.
NFR-02	Compliance	Full PIPEDA compliance required. Consent fields (pipeda_consent, privacy_settings, security_agreement_signed) must be captured at registration and stored at the user model level.
NFR-03	Performance	System must support concurrent users without degradation. QR scan-to-data-display must not exceed 3 seconds under normal network conditions.
NFR-04	Usability	Any user type must complete their primary task (register, update profile, scan QR) within 30 minutes of onboarding. Interface must be fully responsive across desktop, tablet, and mobile.
NFR-05	Reliability	Structured error handling required for all critical user flows. Invalid or unreadable QR codes must return a clear error message, not a system crash.
NFR-06	Maintainability	Codebase must follow documented coding standards. Version control via GitHub with structured branching. Schema changes must be coordinated against the ERD and Data Dictionary.

7. Process Overview

7.1 Current State (AS-IS)

A first responder arrives at an emergency involving a patient who is unconscious or non-verbal. The responder has no access to the patient's medical history, allergy information, or emergency contacts. They must either wait for a family member to arrive, attempt to access a locked phone, or proceed with treatment blind, risking adverse reactions to medications or missed contraindications.

7.2 Future State (TO-BE)

The same first responder sees a MyHealthQR card or sticker on the patient. They scan it using any mobile device. Within seconds, the patient's Quick Help emergency instructions, allergy list, chronic conditions, current medications, and emergency contacts appear on screen with no login required. The responder has the information needed to make a safe, informed treatment decision immediately.

7.3 Key Process Flows

- Account creation and email verification flow
- Login and multi-step authentication flow
- Patient profile and medical data update flow
- QR code generation flow (auto-triggered post-email-verification)
- Third-party QR code scan and data retrieval flow

8. Use Case Summary

ID	Use Case	Primary Actor	Notes
UC-01	User Registration	Patient / User	Email verification required; guardian consent for minors
UC-02	Add or Update Personal Information	Authenticated User	Includes privacy toggle controls per field
UC-03	Add or Update Medical Information	Authenticated User	Self-reported; disclaimer required on save
UC-04	QR Code Scanning	Third-Party User	No login required; scan event logged with timestamp
UC-05	Quick Help Feature	Third-Party User	Priority panel; content determined by patient's toggles
UC-06	System Admin: View and Delete User Data	System Administrator	v1: executed at database level via pre-seeded admin role. Admin UI dashboard is a future enhancement.

Detailed use case specifications including pre-conditions, main success paths, alternate flows, and post-conditions were produced for all six use cases as part of the project documentation.

9. User Stories with Acceptance Criteria

US-01: As a new user, I want to register with a unique email and secure password so that I can create and manage my health profile safely.

Acceptance Criteria: Email uniqueness validated on submission. Password must meet complexity requirements (8+ characters, uppercase, lowercase, number, special character). Verification email sent before account activation. Registration confirmation displayed post-activation. PIPEDA, privacy, and security consents captured and stored.

US-02: As an authenticated user, I want to control which fields in my profile are visible to third-party scanners so that I can protect information I do not want to share publicly.

Acceptance Criteria: Privacy toggles available for all externally visible fields. Toggle state persisted in the database. QR scan results reflect current toggle state in real time. No field is shared externally without explicit user enablement.

US-03: As a third-party user (first responder), I want to scan a patient's QR code and immediately see their approved health information so that I can provide appropriate emergency care.

Acceptance Criteria: QR scan works on any mobile device with a browser and internet access. Approved data displays within 3 seconds. Only user-approved fields are shown. Quick Help instructions appear as a priority panel. Scan event is logged with timestamp.

US-04: As a system administrator, I want to be able to view and delete user accounts so that I can maintain system integrity and fulfill data removal requests under PIPEDA.

Acceptance Criteria: Admin role is enforced via RBAC middleware and cannot be assumed by a standard user. Admin can view registered user records. Admin can permanently delete user accounts. In v1, these operations are executed at the database level using the pre-seeded admin role. Dedicated admin UI dashboard is a future enhancement.

10. Assumptions, Constraints, and Dependencies

10.1 Assumptions

- All users have access to a device with internet connectivity.
- User-entered medical data is self-reported and not clinically validated. Users accept responsibility via an on-screen disclaimer at save.
- The system is designed for deployment in Canada and is built for PIPEDA compliance, not HIPAA or GDPR.
- Users will have basic digital literacy and can complete registration without dedicated technical support.
- QR codes will be printed or displayed by users; the system does not issue physical cards.

10.2 Constraints

- No access to real healthcare providers for primary requirements validation; user needs were derived from research and team analysis.
- Development timeframe fixed at 16 weeks across four milestones (January to April 2025).
- No cloud deployment budget in v1; production hosting deferred to future scope.
- Admin management of user data in v1 is limited to database-level access; no dedicated admin UI was in scope.

10.3 Dependencies

- Laravel built-in authentication, middleware, and email verification system
- PostgreSQL for relational and JSON data storage
- GitHub for version control and team collaboration
- Gmail SMTP for email verification in development and production environments
- Laragon for local development environment (Laravel + PostgreSQL stack)

11. Risk Register

ID	Risk	Likelihood	Impact	Mitigation
R-01	Third party scans QR and sees data patient did not intend to expose	Medium	High	Granular privacy toggles; sensitive fields default-off; user education at registration
R-02	Inaccurate self-reported medical data leads to inappropriate emergency treatment	High	High	Disclaimer displayed on save; system explicitly does not validate clinical accuracy; medical fields are self-reported and labelled as such
R-03	PIPEDA non-compliance due to missing or incomplete consent capture	Low	High	Three consent fields (pipeda_consent, privacy_settings, security_agreement_signed) required at registration; enforced at model validation level
R-04	QR code collision or guessable identifier exposes wrong patient data	Low	Critical	QR codes use randomly generated unique identifiers, not sequential IDs or any PII, and profile data is never embedded in the code itself
R-05	Frontend/backend field mismatch causes data not saving correctly	Medium	Medium	Identified and resolved in Milestone 4 through paired debugging between Technical Lead and Scrum Master; field naming convention standardized across team
R-06	Scope creep from stakeholder requests for EHR integration	Low	Medium	Explicitly documented as out of scope in Project Charter; formally signed off by both project professors at Milestone 1

12. Success Metrics

Metric	Target	Result
All primary use cases functional and demonstrable	5 of 5 use cases pass demo without critical failure	Achieved
Security defects in final UAT	Zero critical defects (auth bypass, unauthorized data exposure, consent gap)	Achieved
QR scan performance	Scan-to-data display under 3 seconds on mobile	Achieved
User story acceptance criteria validation	All defined user stories pass acceptance criteria	Achieved
Project supervisor sign-off	Formal approval from both professors	Achieved
Capstone showcase outcome	Successful demonstration to judges	1st Place

13. Glossary

Term	Definition
BRD	Business Requirements Document: a formal document capturing business needs, objectives, scope, stakeholders, and requirements for a project or system.
PIPEDA	Personal Information Protection and Electronic Documents Act, the Canadian federal privacy legislation governing how private-sector organizations collect, use, and disclose personal information.
QR Code	Quick Response Code: a two-dimensional barcode scannable by mobile devices, used in this system to link a user's physical presence to their digital health profile.
RBAC	Role-Based Access Control: a security model where system access is restricted based on the roles assigned to individual users (User, Third-Party Scanner, System Administrator).
CRUD	Create, Read, Update, Delete: the four fundamental operations for managing data in a persistent storage system.
Laravel	An open-source PHP web application framework used as the backend technology for MyHealthQR, providing authentication, routing, middleware, and ORM capabilities.
PostgreSQL	An open-source, enterprise-class relational database system used to store user profiles, medical data, QR code records, and audit logs.
UAT	User Acceptance Testing: the final phase of testing in which the system is evaluated against business requirements to ensure it meets user needs before sign-off.
EMT / First Responder	Emergency Medical Technician or other first-response personnel who may need to access a patient's critical health information rapidly at the scene of an emergency.

14. Sign-Off

Name	Role	Date	Status
Namrata Modha	Technical Lead & BSA Contributor	April 17, 2025	Approved
Brian Quimod	Project Manager	April 17, 2025	Approved
Professor Vinnie Moraes	Academic Supervisor	April 2025	Approved
Professor Mona Abou Taka	Academic Supervisor	April 2025	Approved

Project Outcome: 1st Place, Fanshawe College BISA Capstone Showcase, April 2025